Is this app safe to show real parents?

Short answer: not yet. 4 problems should be fixed before any real parent signs up, about 6 hours of work. None needs a rebuild.

This is a demo app I built for this sample, with problems planted on purpose. Every number was measured on the demo by the scripts that ship with it.

▲ **Fix before inviting anyone**
4
6 h · about $271 at $45/h

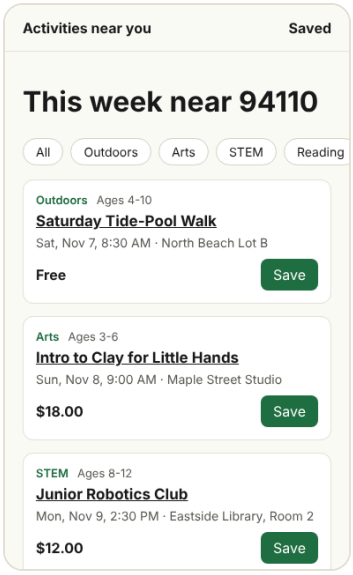
◆ **Fix before public launch**
3
1.5 h · about $69 at $45/h

● **Fix in the first month**
2
0.75 h · about $34 at $45/h

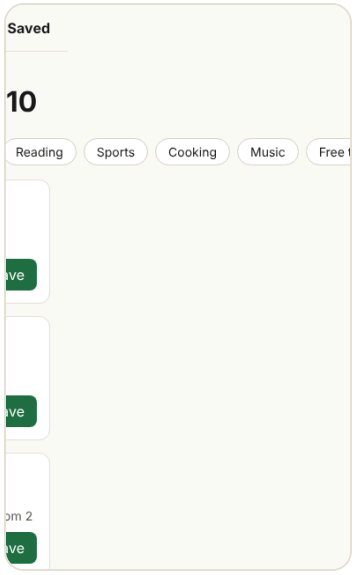
What to fix, in order

	Problem, in plain English	Fix	Hours	Cost
▲ P0	**The master database key is sent to every visitor's browser** Whoever has this key can read or change any table, ignoring every rule you set.	Rename it to a server-only variable, make the Save button act as the signed-in parent, and replace the key in Supabase: a key that has shipped publicly has to be treated as public.	1.5	$68
▲ P0	**Every parent's profile, including children's names and birth years, is readable by anyone** Children's details and home areas of every family on the platform are exposed.	Each parent reads only their own profile. If a public display name is needed, publish just that column through a separate view.	1.5	$68
▲ P0	**Saved lists have no access rules at all** Which family saved which activity is open, and so is adding or deleting other families' saves.	Turn row-level security on and add three owner-only rules: read, add and remove your own saves.	1	$45
▲ P0	**Anyone can create activity listings without signing in** Spam or fake listings on a site parents trust for their kids.	Require a signed-in organizer, write as that user so the database rules apply, and validate the fields (title required, length limits).	2	$90
◆ P1	**Any signed-in parent can edit anyone else's review** Reviews can be rewritten by other users.	Authors edit only their own reviews.	0.5	$23
◆ P1	**The Saved page opens for signed-out visitors** A private page renders for people who are not signed in.	Add /saved to the sign-in check.	0.5	$23
◆ P1	**On phones the home page slides sideways** Parents on phones (most of them) get a page that shifts under their thumb.	Let the category row scroll by itself.	0.5	$23
● P2	**Nothing stops your real keys file from going to GitHub** Keys leaking through the code repository.	Add a .gitignore that excludes .env files.	0.25	$11
● P2	**Ratings are not limited to 1-5, and review text has no length limit** Broken averages and oversized posts.	Database checks: rating between 1 and 5, review up to 2,000 characters.	0.5	$23
	Total		**8.25**	**$374**

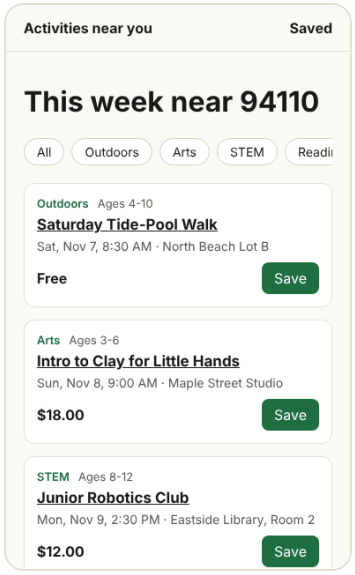
What a parent sees on a phone (390 px, production build)



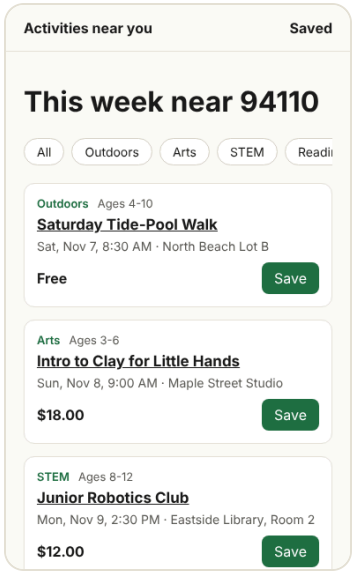
Before: looks fine



Before, swiped: page slides 320px



After: chips scroll on their own



After, swiped: page moves 0px

How each finding was checked

Schema and code scan

9 → 0

scanner flags before → after · 15/15 scanner tests pass

Build check, marker keys

3 → 0

browser files holding the admin key, of 20

Real browser

4 → 0

layouts that slide sideways · signed-out /saved: 200 → 307

Already right: activity listings and reviews are public on purpose and hold no personal data; organizers can change only their own listings; organizer contact details are locked.

All checks are defensive: they read the code, the build output and pages in a browser. Nothing is run against a live system. Finding F9 came from reading the schema, not from a tool.

The PlayLoop review

Included

- Architecture read-through
- Sign-up, sign-in, sessions, private pages
- Every table's access rules vs who should see what
- Keys and env variables, including what reaches the browser
- Server routes and actions: who can call, what they accept
- Core features by hand on phone and desktop
- Bugs and technical debt worth fixing before launch
- Plain-English report with priorities and per-item costs
- 30-minute walkthrough call

Not included

- Making the fixes (quoted per item)
- A rebuild or long-term contract
- Penetration or load testing of a live system
- Legal or privacy-law advice
- Design or copy changes

$480 fixed

3 business days from access. Read-only access is enough. Code, accounts and report stay yours.